

Inteligência de dados aplicada à segurança: priorização estratégica de CWEs

Bruna Lopes de Souza¹, Davi Fernandes Ferreira Silva¹,
Gabriel Henrique Silva Pereira¹, Izabela Cecília S. Barbosa¹,
Lucas Ribeiro do Nascimento¹, Rafael de Paiva Gomes¹,
Vinicius Ramalho¹

¹Instituto de Ciências Exatas e Informática –
Pontifícia Universidade Católica de Minas Gerais (PUC Minas)
Belo Horizonte – MG – Brasil

{bلسouza,gabriel.pereira.676690,icsbarbosa}@sga.pucminas.br
{lucas.nascimento.1266469,vinicius.ramalho.591588}@sga.pucminas.br
davif127@gmail.com, rafaeldepaivagomes@outlook.com

Abstract. *This paper prioritizes Common Weakness Enumeration (CWE) categories in the National Vulnerability Database (NVD) by integrating frequency, Common Vulnerability Scoring System (CVSS) severity, and the interaction between these dimensions. The study applies a reproducible pipeline to NVD records from 1999 to 2025 and computes metrics for concentration, average severity, HIGH/CRITICAL proportion, composite risk, temporal trend, and risk quadrants. The results show strong concentration among few CWE categories, low correlation between frequency and severity, and a small group of weaknesses that combine high recurrence and high technical impact.*

Resumo. *Este trabalho prioriza categorias de Common Weakness Enumeration (CWE) na National Vulnerability Database (NVD) por meio da integração entre frequência, severidade do Common Vulnerability Scoring System (CVSS) e interação entre essas dimensões. O estudo aplica um pipeline reprodutível aos registros da NVD entre 1999 e 2025 e calcula métricas de concentração, severidade média, proporção HIGH/CRITICAL, risco composto, tendência temporal e quadrantes de risco. Os resultados mostram forte concentração em poucas categorias de CWE, baixa correlação entre frequência e severidade e um grupo reduzido de fraquezas que combina alta recorrência e alto impacto técnico.*

1. Introdução

A gestão de vulnerabilidades em *software* tornou-se uma atividade central para equipes de desenvolvimento e segurança, especialmente diante do crescimento contínuo dos registros públicos de falhas e dos custos associados a incidentes de segurança [Gueye and Mell 2021, IBM Security 2025, Anwar et al. 2022]. Nesse contexto, a *National Vulnerability Database* (NVD), mantida pelo *National Institute of Standards and Technology* (NIST), consolida registros de *Common Vulnerabilities and Exposures* (CVE), classificações por *Common Weakness Enumeration* (CWE) e escores do *Common Vulnerability Scoring System* (CVSS). Esses três elementos permitem deslocar a análise da vulnerabilidade isolada para padrões recorrentes de fraqueza, oferecendo uma base adequada para decisões de priorização [Gueye and Mell 2021, Mell and Gueye 2020].

A escolha por CVE, CWE e CVSS decorre do papel complementar desses elementos. O CVE identifica a ocorrência específica, o CWE agrupa a causa ou padrão de fraqueza associado a essa ocorrência, e o CVSS fornece uma medida padronizada de severidade técnica. Assim, a análise por CWE permite sair da correção caso a caso e observar quais classes de falha devem receber maior atenção preventiva.

O problema investigado neste trabalho é a ausência de um critério integrado, simples e reproduzível para priorizar fraquezas de segurança a partir de dados históricos da NVD. Embora frequência, severidade e exploração sejam dimensões recorrentes em estudos de vulnerabilidades, elas muitas vezes são analisadas separadamente, o que limita sua utilidade para equipes com recursos finitos de correção [Mell and Gueye 2020, Albanese et al. 2023, Jacobs et al. 2021]. Este estudo parte de duas premissas: a distribuição de ocorrências por CWE é concentrada, e frequência e severidade técnica não necessariamente apontam para as mesmas fraquezas. Por isso, a priorização exige uma leitura conjunta dessas dimensões, sem confundir severidade potencial com probabilidade real de exploração.

A relevância do problema decorre do volume de registros publicados continuamente, que torna insuficiente a correção caso a caso de CVEs. Quando a análise é organizada por CWE, torna-se possível reconhecer causas recorrentes de falha e orientar ações de prevenção, treinamento, auditoria e alocação de esforço técnico [Galhardo et al. 2020, Gueye et al. 2021, Mell and Gueye 2020]. Além disso, a combinação entre frequência e severidade tende a produzir evidências mais úteis para decisão do que o uso isolado de escores ou contagens absolutas [Allodi and Massacci 2014, Allodi et al. 2020, Sharma et al. 2023].

O objetivo geral deste trabalho é identificar e priorizar os tipos de fraqueza de *software* com maior risco relativo na base NIST NVD, por meio da análise integrada de frequência histórica, severidade técnica e interação entre essas dimensões. Para isso, adota-se o paradigma *Goal-Question-Metric* (GQM), no qual um objetivo analítico é desdobrado em perguntas de pesquisa e métricas observáveis [Basili et al. 1994]. Como objetivos específicos, busca-se: (a) caracterizar a concentração de CVEs entre categorias de CWE; (b) mensurar severidade média e proporção de casos graves por fraqueza; (c) calcular um indicador composto de risco; (d) avaliar a associação entre frequência e severidade; e (e) identificar CWEs que combinam alta recorrência e alta severidade.

A partir desses objetivos, o estudo formula três perguntas de pesquisa. A primeira (P1) investiga quais tipos de fraqueza concentram o maior número de vulnerabilidades reportadas na NVD. A segunda (P2) examina quais CWEs apresentam maior severidade técnica e potencial de dano. A terceira (P3) avalia se uma fraqueza frequente tende também a ser severa ou se essas dimensões se comportam de forma independente. Cada pergunta é associada a hipóteses, métricas e testes estatísticos detalhados na Seção 3.

Como resultado, este trabalho apresenta um panorama empírico das fraquezas mais recorrentes, mais severas e pertencentes ao quadrante de dupla ameaça na NVD entre 1999 e 2025. Esse panorama sustenta um *ranking* priorizado de CWEs e oferece evidências para que desenvolvedores, gestores de segurança e auditores direcionem recursos de correção de forma mais objetiva. Como contribuição adicional, o *pipeline* computacional desenvolvido para a pesquisa é disponibilizado publicamente, com suporte a

filtros por *vendor*, de modo que outras equipes possam replicar a análise em contextos organizacionais específicos.

Além desta introdução, o trabalho está organizado da seguinte forma. A Seção 2 discute estudos relacionados e delimita a lacuna enfrentada pela pesquisa. A Seção 3 descreve a metodologia de forma objetiva, com os detalhes técnicos extensos preservados nos apêndices complementares. A Seção 4 apresenta os resultados obtidos para P1, P2 e P3. A Seção 5 interpreta os achados e discute suas implicações. Por fim, a Seção 7 sintetiza as contribuições e indica trabalhos futuros.

2. Trabalhos Relacionados

Esta seção apresenta trabalhos que tratam da priorização de fraquezas de segurança por frequência, severidade e uso de dados históricos da NVD. Foram selecionados cinco estudos diretamente relacionados ao problema investigado. A organização adotada parte de abordagens centradas em métricas de priorização, passa por estudos de qualidade dos dados e conclui com evidências sobre concentração de ocorrências, de modo a explicitar a lacuna metodológica explorada neste trabalho.

Mell e Gueye (2020) [Mell and Gueye 2020] propõem um conjunto de métricas para identificar os tipos de falha de segurança mais significativos a partir da combinação entre frequência, explorabilidade, impacto e severidade em registros da NVD. O método organiza dimensões do CVSS e da classificação por CWE em uma estrutura de mensuração voltada ao ranqueamento de fraquezas. Como resultado, o trabalho mostra que a combinação entre essas dimensões produz classificações mais informativas do que o uso isolado de contagens absolutas. A relação com a presente pesquisa é direta, pois a ideia de integrar frequência e severidade é reaproveitada aqui, embora em uma formulação mais simples, interpretável e reproduzível.

Galhardo *et al.* (2020) [Galhardo et al. 2020] aprofundam essa discussão ao desenvolver a métrica *Most Significant Software Security Weaknesses* (MSSW) para classificar fraquezas de *software* com base em dados da NVD. O método combina frequência por CWE com componentes de severidade do CVSS e demonstra, por meio de análises de distribuição, que algumas fraquezas concentram recorrência e impacto simultaneamente. Entre os resultados, destaca-se a evidência de que equações anteriores atribuíam peso excessivo à frequência, o que motivou ajustes na forma de balancear as dimensões. A relação com a presente pesquisa está no fato de que ambos os estudos tratam do ranqueamento de CWEs, mas o presente trabalho busca complementar essa linha com métricas mais fáceis de interpretar e comparar.

Albanese *et al.* (2023) [Albanese et al. 2023] apresentam um *framework* formal para o desenho de métricas de vulnerabilidade e o aplicam ao cálculo de frequência e severidade por CWE em dados da NVD. O método define equações explícitas para frequência normalizada, severidade média e escore global por fraqueza, além de comparar os resultados com listas consolidadas da literatura. Como resultado, o estudo mostra que o uso exclusivo do CVSS é insuficiente para priorização e que sua combinação com frequência fornece uma base mais consistente para ordenar fraquezas. A relação com a pesquisa proposta é estreita, porque este trabalho também constrói métricas por CWE, mas amplia essa abordagem ao incorporar medidas de concentração, proporção de casos graves e associação estatística entre classificações.

Anwar *et al.* (2022) [Anwar et al. 2022] investigam a qualidade dos dados da NVD por meio de uma avaliação abrangente de inconsistências, ausências e imprecisões em campos usados por estudos empíricos. O método combina limpeza de dados, análise quantitativa e verificação de problemas em classificações, incluindo registros de CWE. Como resultado, o artigo mostra que erros, imprecisões e lacunas na base podem afetar conclusões sobre distribuição de vulnerabilidades e, por consequência, comprometer processos de priorização. A relação com o presente estudo decorre do uso da NVD como base empírica principal, razão pela qual esta pesquisa incorpora cuidado explícito com seleção de campos, limpeza e tratamento de registros antes do cálculo das métricas.

Liu *et al.* (2020) [Liu et al. 2020] analisam a distribuição de vulnerabilidades em projetos de código aberto para verificar como as ocorrências se concentram em poucos tipos de fraqueza. O método baseia-se em um estudo empírico de larga escala, com agrupamento por categorias de CWE e comparação da concentração entre projetos e tipos de vulnerabilidade. Entre os principais resultados, os autores mostram que uma parcela pequena de categorias concentra a maior parte dos registros, o que reforça a utilidade analítica de observar distribuição acumulada e concentração. A relação com a presente pesquisa está no aproveitamento dessa perspectiva de concentração, aqui transferida para uma análise histórica mais ampla na NVD, com foco em priorização global e não apenas em projetos específicos.

Em conjunto, os cinco trabalhos mostram que a literatura já reconhece a importância de integrar informação estrutural da NVD, classificação por CWE e medidas derivadas do CVSS para apoiar priorização. Ainda assim, nenhum dos estudos examinados produz, sobre a série histórica completa da NVD, um diagnóstico que combine concentração de frequência, severidade média por CWE, proporção de casos graves por CWE, escore composto transparente e teste formal de associação entre as duas dimensões. Especificamente, o percentual acumulado dos tipos mais frequentes (M2), a proporção de casos *HIGH/CRITICAL* por CWE individual (M4), o quadrante de dupla ameaça (M8) e a correlação de Spearman entre *rankings* de frequência e severidade (M6) não foram identificados, em conjunto, nos artigos analisados na operacionalização aqui proposta. É nessa lacuna empírica que a presente pesquisa se insere.

3. Materiais e Métodos

Esta seção descreve o caminho metodológico adotado para transformar registros brutos da NVD em evidências de priorização por CWE. A pesquisa é aplicada, quantitativa, descritiva e correlacional, pois usa dados estruturados da NVD para caracterizar frequência, severidade e associação entre essas dimensões. A estratégia de observação é censitária, considerando todos os registros disponíveis na API da NVD entre 1999 e 2025 que atendem aos critérios de inclusão. O fluxo metodológico, apresentado na Figura 1, mostra as etapas de extração dos dados, pré-processamento, cálculo das métricas e validação estatística.

Na extração, os registros de CVE são obtidos da API pública da NVD no período definido. No pré-processamento, mantêm-se as associações úteis entre CVE, CWE e CVSS, descartando registros sem classificação válida para a análise por fraqueza. No cálculo das métricas, cada CWE é caracterizada por frequência, concentração, severidade, proporção de casos *HIGH/CRITICAL*, risco composto, tendência e quadrante de risco. Na

validação estatística, os resultados são examinados por medidas de concentração, testes de diferença entre grupos e correlação entre os *rankings* de frequência e severidade.

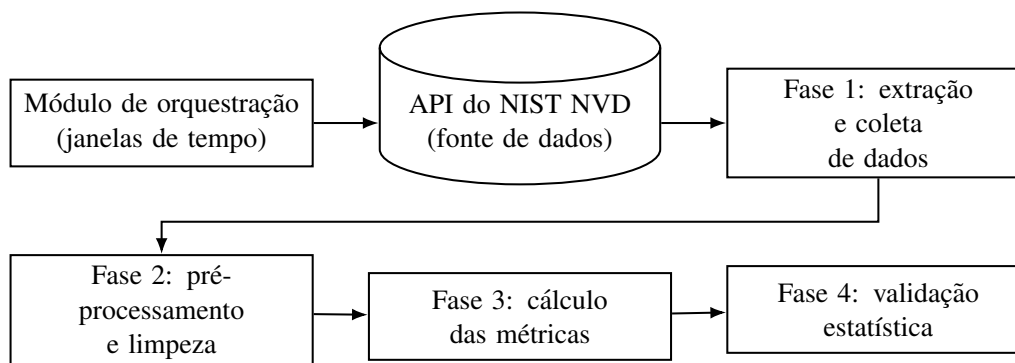


Figura 1. Fluxo metodológico da análise de dados

Fonte: Elaborado pelos autores.

3.1. Unidade de análise e estrutura de medição

Como indicado na introdução, a unidade de análise do estudo é a categoria de CWE, e não o CVE individual. Essa escolha permite agrupar vulnerabilidades que derivam de um mesmo padrão de fraqueza e, portanto, aproxima a análise de decisões preventivas, como treinamento, revisão de código e adoção de controles específicos [Mell and Gueye 2020, Galhardo et al. 2020, Gueye and Mell 2021]. O CVSS é utilizado como medida padronizada de severidade técnica associada aos CVEs, enquanto a NVD fornece a base histórica que conecta CVEs, CWEs e pontuações de severidade.

A estrutura de medição retoma e detalha o paradigma GQM já definido na introdução, com o objetivo de manter rastreabilidade entre objetivo, perguntas de pesquisa e métricas. Assim, P1 é operacionalizada por métricas de frequência e concentração; P2, por métricas de severidade e proporção de casos graves; e P3, por medidas de interação entre frequência e severidade. Essa organização reduz a dispersão analítica e torna explícito como cada resultado contribui para responder ao problema de priorização.

3.2. Ambiente computacional e materiais empregados

O ambiente de execução é composto pela API pública da NVD, *scripts* em *Python* 3.10+, manipulação tabular com *pyarrow* $\geq 14.0.0$, análises estatísticas com *SciPy* $\geq 1.10.0$ e geração de visualizações e tabelas. Esse conjunto permite coletar dados em *JavaScript Object Notation* (JSON), tratar registros em larga escala e aplicar testes estatísticos compatíveis com as perguntas de pesquisa. A literatura reforça a relevância de ambientes baseados em dados estruturados da NVD para estudos empíricos desse tipo [Ponte et al. 2023, Anwar et al. 2022].

Os insumos principais são a própria NVD, os campos de CVE, CWE e CVSS extraídos da API, os *scripts* de consulta e limpeza e os artefatos de documentação. Para consulta complementar, as demais dependências computacionais, os parâmetros operacionais de coleta e os elementos de reprodutibilidade são sintetizados no Apêndice A.2. Esse apêndice detalha aspectos técnicos úteis à replicação, enquanto o corpo principal apresenta apenas os materiais e decisões metodológicas indispensáveis para compreender

o estudo. Como o processo não depende de hardware especializado nem de *frameworks* proprietários, sua replicação por outras equipes é facilitada.

3.3. Configuração experimental e variáveis

A configuração experimental considera como população todos os registros da NVD publicados entre 1999 e 2025 que possuem associação válida com CWE após o pré-processamento. A variável independente principal é a categoria de fraqueza (CWE), usada para agrupar as vulnerabilidades. O ano de publicação é utilizado como variável temporal para análises de tendência e persistência do *ranking*.

As variáveis dependentes são as métricas calculadas para cada CWE: frequência de CVEs, percentual acumulado, CVSS médio, proporção de casos *HIGH/CRITICAL*, escore de risco composto, posição nos *rankings*, pertencimento ao quadrante de dupla ameaça e medidas de estabilidade temporal. Essa configuração conecta diretamente cada pergunta de pesquisa aos dados observados e às métricas usadas para respondê-la.

3.4. Métodos, métricas e instrumentos

O método combina coleta automatizada, limpeza de dados, agregação por categoria de fraqueza, cálculo de métricas e validação estatística. As métricas centrais M1 a M8 cobrem frequência absoluta, concentração acumulada, severidade média, proporção de casos de severidade alta ou crítica (*HIGH/CRITICAL*), escore composto de risco, associação entre *rankings*, tendência temporal e classificação por quadrantes. Em conjunto, essas métricas permitem observar o problema sob três perspectivas complementares: recorrência, impacto técnico e interação entre recorrência e impacto [Mell and Gueye 2020, Galhardo et al. 2020, Albanese et al. 2023].

As hipóteses são formuladas a partir das três perguntas de pesquisa apresentadas na introdução. Para P1, pergunta voltada à frequência e à concentração de vulnerabilidades por CWE, considera-se como hipótese nula que a distribuição de CVEs entre CWEs não apresenta concentração relevante. As hipóteses alternativas H1 e H2 verificam, respectivamente, se a distribuição é concentrada e se um subconjunto reduzido de categorias domina a base.

Para P2, pergunta voltada à severidade técnica e à proporção de casos graves por fraqueza, a hipótese nula assume igualdade nas distribuições de CVSS e homogeneidade na proporção de casos *HIGH/CRITICAL* entre CWEs. As hipóteses alternativas H3 e H4 avaliam se o CVSS médio e a proporção de casos graves diferem significativamente entre fraquezas. Para P3, pergunta voltada à interação entre frequência e severidade, a hipótese nula assume ausência de associação entre essas dimensões e inexistência de um subconjunto destacado de dupla ameaça. As hipóteses alternativas H5 e H6 examinam se o escore composto concentra valores elevados em poucas CWEs e se há correlação monotônica entre o *ranking* de frequência e o *ranking* de severidade técnica.

Além das métricas centrais, são utilizados indicadores suplementares para dar robustez à interpretação dos resultados. O índice de Gini e a curva de Lorenz (M9) formalizam a concentração derivada de M1. A persistência anual do *top-20* por Jaccard (M10) avalia a estabilidade temporal do *ranking*. A sobreposição entre *top-10* de frequência, severidade e risco composto (M11) verifica se os diferentes critérios de priorização selecionam as mesmas CWEs ou conjuntos distintos. Esses indicadores não substituem

as métricas principais, mas ajudam a interpretar concentração, estabilidade e divergência entre critérios.

3.5. Testes estatísticos adotados

A validação das métricas utiliza testes estatísticos e indicadores suplementares compatíveis com a estrutura dos dados e com as hipóteses operacionalizadas nesta seção. Para P1, voltada à frequência e à concentração, a concentração de ocorrências é examinada pelo índice de Gini e pela curva de Lorenz. A dominância do subconjunto mais frequente é avaliada pelo percentual acumulado (M2).

Para P2, voltada à severidade técnica, a diferença de severidade entre grupos de CWE é avaliada pelo teste de Kruskal-Wallis. A diferença na proporção de casos *HIGH/CRITICAL* é analisada pelo qui-quadrado de homogeneidade. Para P3, voltada à interação entre recorrência e severidade, a estrutura do escore composto é examinada pela distribuição dos valores de M5 e pela classificação em quadrantes (M8). Essa análise é complementada pelo teste de Mann-Whitney entre o grupo de dupla ameaça e as demais CWEs, quando aplicável. A associação entre ordenações produzidas por frequência e severidade é avaliada pela correlação de Spearman, complementada pela sobreposição de *rankings* por meio do índice de Jaccard [Gueye and Mell 2021, Liu et al. 2020, Williams et al. 2018].

A escolha por técnicas não paramétricas decorre do comportamento concentrado esperado para os dados de vulnerabilidade. Como as contagens por fraqueza tendem a apresentar assimetria e dispersão elevada, esses testes oferecem maior robustez para avaliar diferenças e associações sem depender de pressupostos fortes de normalidade. Em conjunto, as métricas centrais, os testes estatísticos e os indicadores suplementares permitem observar o problema sob as perspectivas de recorrência, severidade, interação, tendência e sobreposição entre critérios de priorização.

4. Resultados

Esta seção apresenta os resultados da execução do *pipeline* descrito na Seção 3 sobre a série histórica da NVD entre 1999 e 2025. A base final contém 253.802 CVEs distintos, 278.912 relações CVE–CWE e 749 categorias de CWE, com cobertura de CVSS de 99,99%. Antes de responder às perguntas de pesquisa, esse panorama confirma a escala do problema: o volume anual de CVEs passou de aproximadamente 56 em 1999 para cerca de 45.000 em 2025. Para análises complementares, o Apêndice B apresenta estatísticas descritivas adicionais, incluindo a distribuição global do CVSS e o *mix* de severidade por ano.

4.1. Frequência e concentração de vulnerabilidades por CWE (P1)

A P1 investiga quais fraquezas concentram mais vulnerabilidades reportadas; por isso, a resposta parte da distribuição de CVEs por CWE. As métricas M1 (frequência absoluta) e M2 (percentual acumulado) mostram quais fraquezas concentram maior volume, enquanto o índice de Gini formaliza o grau de desigualdade dessa distribuição. Essa leitura permite verificar se a priorização pode se concentrar em poucas categorias ou se o problema está disperso no catálogo. A Figura 2 apresenta o diagrama de Pareto usado para sintetizar essa distribuição.

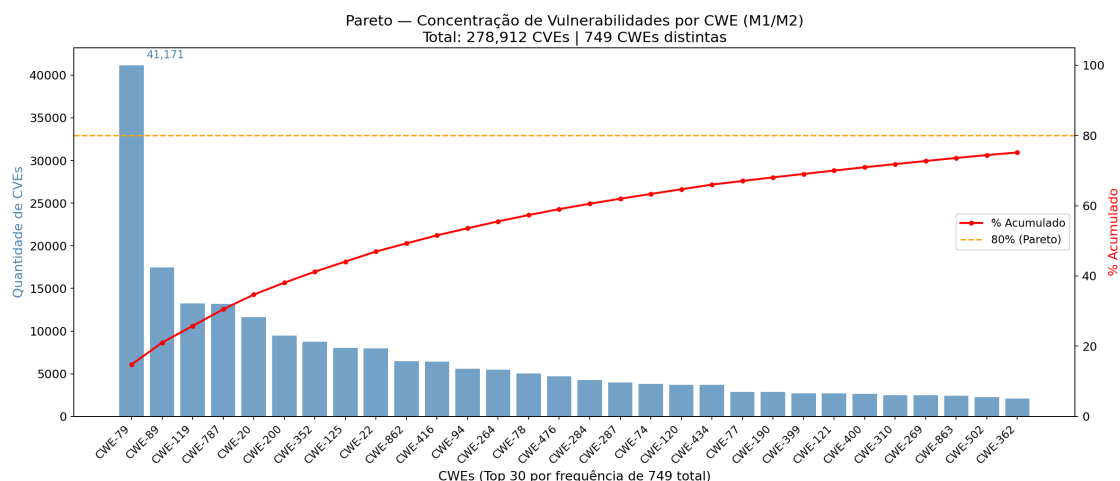


Figura 2. Diagrama de Pareto: frequência absoluta de CVEs por CWE (M1) e percentual acumulado (M2).

No diagrama de Pareto, as CWEs são ordenadas por frequência decrescente. A CWE-79 (*Cross-Site Scripting*) lidera com 41.171 CVEs, valor cerca de 2,4 vezes superior ao da segunda colocada, CWE-89 (*SQL Injection*, 17.467). As 11 primeiras CWEs cobrem 50% de todas as relações CVE–CWE, e apenas 39 CWEs, correspondentes a 5% das 749 distintas, acumulam 80% do total. No extremo oposto, 101 CWEs possuem exatamente uma única CVE associada, e a mediana de CVEs por CWE é 11, enquanto a média é 372, o que evidencia a assimetria da distribuição.

O índice de Gini calculado sobre a distribuição de CVEs por CWE é $G = 0,922$, próximo do limite teórico de 1. Os 10% de CWEs com maior volume concentram 90,0% das CVEs, e os 20% superiores concentram 96,5%. Três CWEs são suficientes para acumular 25% de toda a base, e 76 CWEs cobrem 90%. Para consulta complementar, a curva de Lorenz correspondente é apresentada no Apêndice B (Figura 8). Esses valores confirmam H1 e H2, hipóteses associadas à concentração e à dominância de poucas categorias: a distribuição é extremamente concentrada e a priorização de um subconjunto restrito de fraquezas tem potencial para cobrir a maior parte do problema.

A análise temporal complementa esse achado. Na métrica temporal M7, usada para observar tendência anual por CWE, a CWE-79 passa a liderar de forma consistente nos anos recentes, com crescimento de 7.371 CVEs em 2024 para 8.297 em 2025. A CWE-862 (*Missing Authorization*), com ocorrências esparsas antes de 2018, alcança 2.357 CVEs em 2025, caracterizando uma fraqueza emergente. Em sentido oposto, a CWE-119 (*Buffer Overflow*) atinge pico em 2017 e permanece abaixo desse patamar nos anos posteriores, apesar de nova elevação em 2025. A persistência do *top-20* entre anos consecutivos, capturada por M10, é moderada a elevada, com índice de Jaccard médio de 0,67. Esse indicador mostra que a composição do *ranking* muda gradualmente. Para análises complementares da dimensão temporal, o *heatmap* CWE $\times$ Ano e os *subplots* de tendência temporal (M7) são apresentados no Apêndice B (Figuras 9 e 10).

4.2. Severidade e impacto por tipo de fraqueza (P2)

A resposta a P2 desloca o foco do volume para o impacto técnico. Para isso, M3 calcula o CVSS médio por CWE, enquanto M4 estima a proporção de CVEs classificados nas faixas *HIGH* ou *CRITICAL*. A intenção é verificar se fraquezas frequentes também são severas ou se a severidade revela prioridades que a contagem absoluta não mostra. A Figura 3 apresenta a distribuição do CVSS para as 20 CWEs mais frequentes.

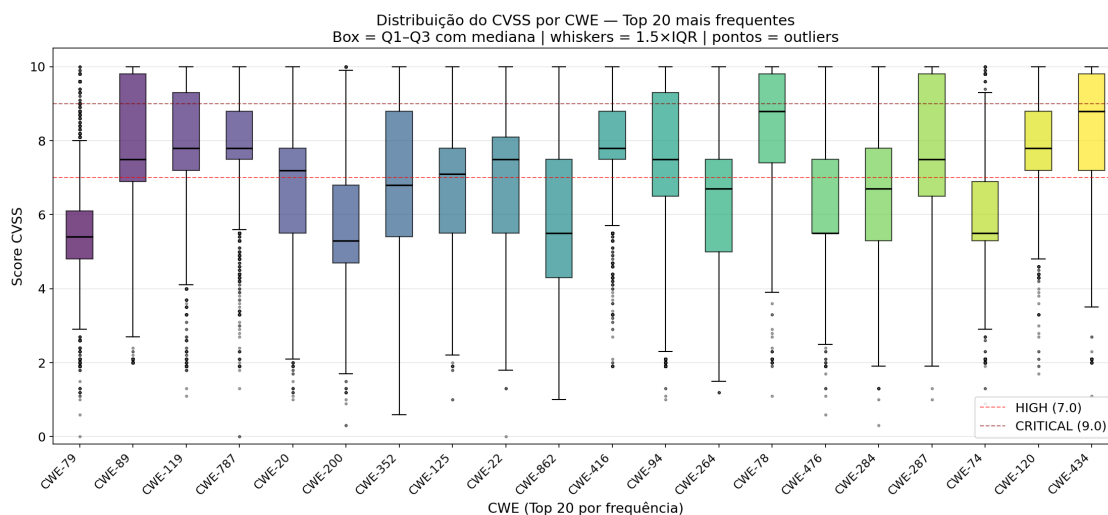


Figura 3. Distribuição do CVSS para as 20 CWEs mais frequentes (boxplot com mediana, quartis e outliers).

A distribuição do CVSS varia consideravelmente entre fraquezas. A CWE-79 (*Cross-Site Scripting*) possui caixa centrada em 5,4, com amplitude interquartil de 1,3, concentrando-se predominantemente na faixa *MEDIUM* e com 6,6% dos casos classificados como *HIGH* ou *CRITICAL*. A CWE-78 (*OS Command Injection*, CVSS médio 8,42) e a CWE-434 (*Unrestricted File Upload*, CVSS médio 8,15) possuem caixas majoritariamente acima do limiar 7,0, com proporção de *HIGH*+*CRITICAL* superior a 80%. A CWE-502 (*Deserialization of Untrusted Data*) atinge CVSS médio de 8,55, com 90,1% dos casos na faixa *HIGH* ou *CRITICAL*. No extremo superior, entre CWEs com pelo menos 30 CVEs, a CWE-917 (*Expression Language Injection*) apresenta o maior CVSS médio (8,92), com 94,2% de *HIGH*+*CRITICAL*.

O teste de Kruskal-Wallis, aplicado às CWEs com pelo menos cinco CVEs, rejeita a hipótese nula de igualdade de distribuições de CVSS entre CWEs ($p < 0,05$), confirmando estatisticamente a heterogeneidade observada nos *boxplots*. O teste qui-quadrado de homogeneidade, aplicado à tabela de contingência CWE × severidade para as dez CWEs mais frequentes, também rejeita a hipótese de proporções iguais de *HIGH*/*CRITICAL* ($p < 0,05$). Como verificação de consistência, o teste de Mann-Whitney U confirma que os *scores* CVSS do grupo *HIGH*/*CRITICAL* são significativamente superiores aos do grupo *LOW*/*MEDIUM* ($p \ll 0,05$), resultado esperado dada a relação intrínseca entre pontuação CVSS e faixas de severidade. Esses resultados confirmam H3 e H4, hipóteses associadas à diferença de severidade e à diferença na proporção de casos graves entre fraquezas: a severidade varia significativamente entre tipos de fraqueza, e CWEs com volumes similares podem esconder perfis de impacto muito distintos.

Para consulta complementar sobre severidade, o gráfico de barras com CVSS médio e proporção *HIGH/CRITICAL* para as 30 CWEs mais severas (M3/M4) e o *mix* de severidade normalizado por ano são apresentados no Apêndice B (Figuras 11 e 12).

4.3. Interação entre frequência e severidade (P3)

A resposta a P3 integra as duas dimensões anteriores. Depois de observar frequência e severidade separadamente, a análise verifica se elas caminham juntas ou se produzem *rankings* distintos. Essa etapa também identifica o subconjunto de dupla ameaça, formado por CWEs que combinam alta recorrência e alta severidade. A Figura 4 apresenta a relação entre frequência e CVSS médio.

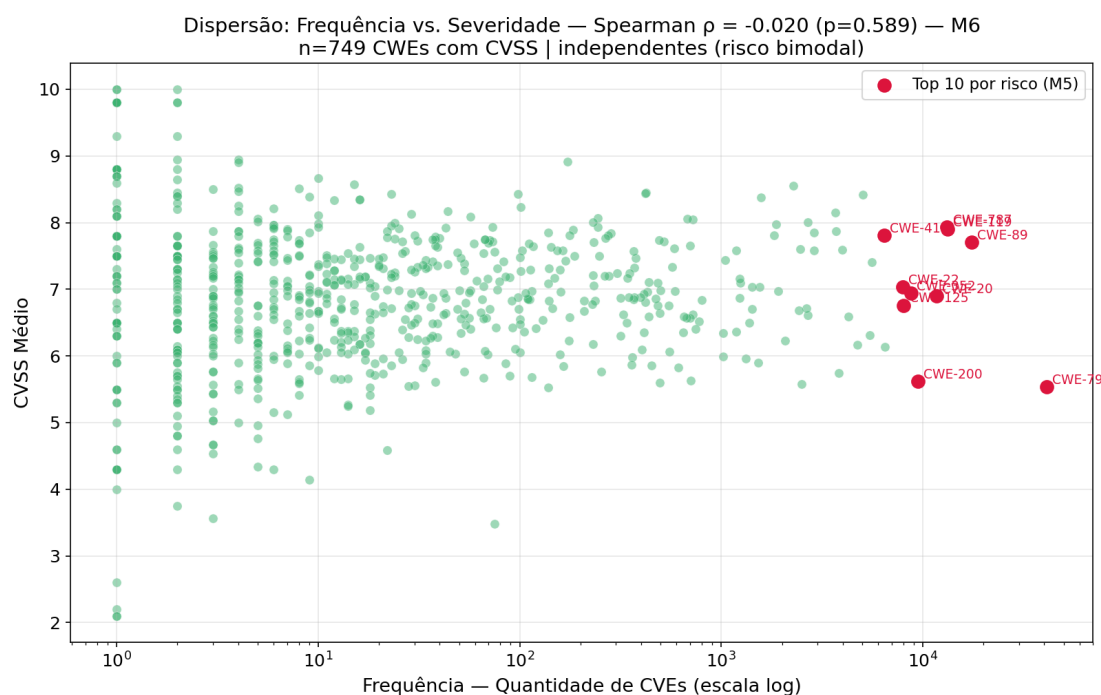


Figura 4. Dispersão entre frequência (escala log) e CVSS médio por CWE, com correlação de Spearman (M6).

No diagrama de dispersão entre frequência (escala logarítmica) e CVSS médio para as 749 CWEs, o coeficiente de Spearman obtido é $\rho = -0,020$ com $p = 0,59$, estatisticamente indistinguível de zero. O coeficiente de Pearson sobre $\log_{10}(\text{freq}) \times \text{CVSS}$ também é desprezível ($r = 0,006$; $p = 0,86$). A reta de regressão é praticamente plana. O índice de Jaccard entre os *top-20* de frequência e de severidade é $J = 0,000$: os dois conjuntos são totalmente disjuntos, sem nenhuma CWE em comum. Esses resultados confirmam a parte de independência prevista em H5/H6, hipóteses ligadas à interação entre frequência e severidade: ser frequente não implica ser severa, e vice-versa. A Figura 5 complementa essa análise ao separar as CWEs por quadrantes de risco.

A classificação das CWEs em quatro quadrantes é definida pelos terceiros quartis de frequência ($Q3_{\text{freq}} = 66$ CVEs) e de CVSS médio ($Q3_{\text{cvss}} = 7,52$). O quadrante de dupla ameaça contém 53 CWEs ($\approx 7\%$), que combinam simultaneamente frequência e severidade acima dos respectivos quartis superiores. Os demais quadrantes distribuem-se em 135 CWEs classificadas como apenas severas, 137 como apenas frequentes e 424

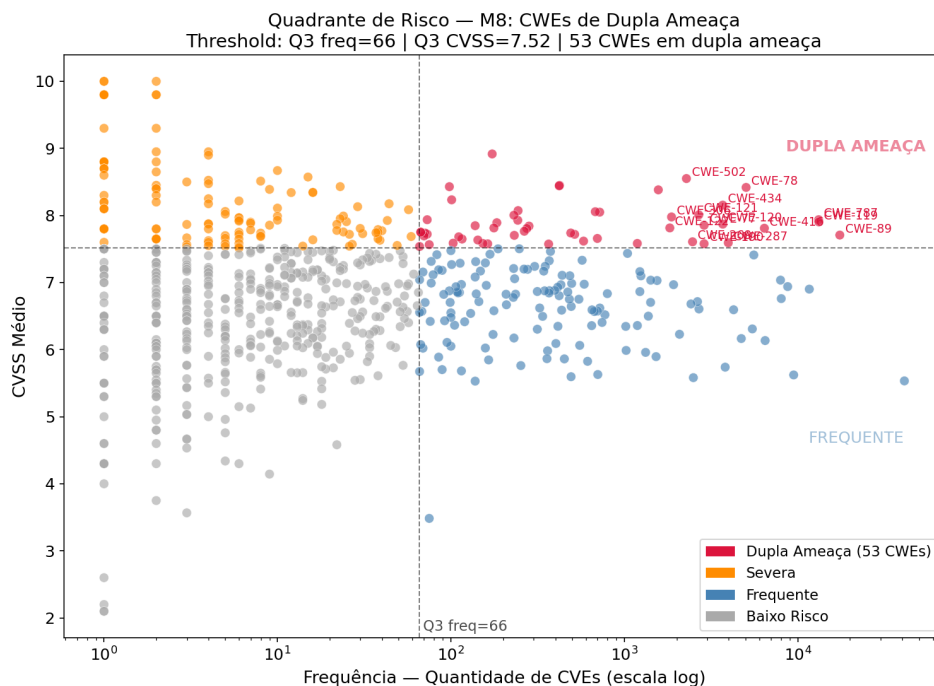


Figura 5. Quadrante de risco (M8): CWEs de dupla ameaça (frequência $\geq$ Q3 e CVSS $\geq$ Q3).

como baixo risco. Entre as CWEs de dupla ameaça, destacam-se CWE-89 (*SQL Injection*), CWE-787 (*Out-of-bounds Write*), CWE-78 (*OS Command Injection*), CWE-416 (*Use After Free*), CWE-502 (*Deserialization of Untrusted Data*), CWE-434 (*Unrestricted File Upload*), CWE-287 (*Improper Authentication*) e CWE-120 (*Buffer Copy without Checking Size*).

Esse resultado confirma a segunda parte de H5/H6, relacionada à existência de um subconjunto de dupla ameaça: embora não exista correlação geral, um subgrupo minoritário de CWEs combina alta frequência com alta severidade. O *score* de risco composto (M5), que sintetiza as duas dimensões em um indicador multiplicativo no intervalo $[0, 1]$, reforça essa concentração: apenas a CWE-79 ultrapassa 0,50 (*score* 0,55), seguida por CWE-89 (0,33), CWE-787 (0,254) e CWE-119 (0,254). A partir da quinta posição, todos os *scores* ficam abaixo de 0,20. Para análises complementares da interação entre critérios, o gráfico de barras do *score* composto e a matriz de sobreposição entre *top-10*, correspondente à métrica M11, são apresentados no Apêndice B (Figuras 13 e 14).

4.4. Síntese dos resultados e *ranking* priorizado

A Tabela 1 apresenta as dez CWEs com maior *score* de risco composto (M5), acompanhadas de frequência absoluta (M1), CVSS médio (M3), proporção de *HIGH+CRITICAL* (M4) e classificação no quadrante de risco (M8). A síntese permite comparar, em um mesmo quadro, recorrência, impacto técnico e posição de cada fraqueza nos quadrantes analisados.

A tabela evidencia que o *score* composto é dominado pelo componente de

Tabela 1. Top-10 CWEs por score de risco composto (M5)

#	CWE	CVEs	CVSS médio	%H+C	Score M5	Quadrante
1	CWE-79	41.171	5,53	6,6	0,553	Frequente
2	CWE-89	17.467	7,71	71,8	0,327	Dupla Ameaça
3	CWE-787	13.192	7,94	81,3	0,254	Dupla Ameaça
4	CWE-119	13.229	7,90	75,9	0,254	Dupla Ameaça
5	CWE-20	11.653	6,90	53,1	0,195	Frequente
6	CWE-352	8.744	6,94	49,0	0,147	Frequente
7	CWE-22	7.952	7,04	56,6	0,136	Frequente
8	CWE-125	8.030	6,76	51,6	0,132	Frequente
9	CWE-200	9.468	5,62	24,0	0,129	Frequente
10	CWE-416	6.418	7,81	82,8	0,122	Dupla Ameaça

Fonte: Elaborado pelos autores.

frequência: a CWE-79, apesar de CVSS médio moderado (5,53), lidera o *ranking* por seu volume excepcional. As CWEs que figuram simultaneamente no *top-10* de M5 e no quadrante de dupla ameaça — CWE-89, CWE-787, CWE-119 e CWE-416 — representam o subconjunto de maior risco agregado, pois combinam volume elevado com CVSS médio acima do terceiro quartil (7,52) e proporção de *HIGH+CRITICAL* superior a 71%. Esse resultado converge com a independência dimensional observada em M6 ($\rho \approx 0$) e demonstra que nenhuma métrica isolada é suficiente para priorização: o *ranking* de frequência e o *ranking* de severidade são complementares, e a combinação de M5 (risco composto) com M8 (quadrante) captura as duas perspectivas.

5. Discussão

Esta seção discute os principais insights produzidos pelo estudo e explicita como as perguntas de pesquisa foram respondidas. Em vez de apenas reiterar os resultados numéricos da Seção 4, a análise destaca as nuances encontradas, os pontos inesperados e as implicações práticas para priorização de fraquezas de *software*.

O trabalho possui caráter descritivo e inferencial, pois organiza evidências históricas da NVD e testa relações entre frequência e severidade. Assim, não utiliza abordagem preditiva nem busca estimar exploração futura de vulnerabilidades.

5.1. Respostas às perguntas de pesquisa

A P1, que investiga frequência e concentração de vulnerabilidades por CWE, foi respondida ao mostrar que a distribuição de CVEs é fortemente concentrada. Esse achado indica que a base NVD não se distribui de forma uniforme entre centenas de fraquezas: um grupo relativamente pequeno de CWEs responde por parcela expressiva dos registros. O primeiro insight do trabalho, portanto, é que ações preventivas orientadas por CWE podem produzir maior cobertura quando começam pelas fraquezas mais recorrentes, em vez de tentar tratar todas as categorias com o mesmo peso.

A P2, voltada à severidade técnica e à proporção de casos *HIGH/CRITICAL*, mostrou que as fraquezas mais frequentes não são necessariamente as mais severas. Essa foi uma nuance importante: algumas CWEs aparecem muitas vezes, mas com severidade

média moderada, enquanto outras, menos recorrentes, concentram maior potencial de dano técnico. O segundo insight é que priorizar apenas por contagem de CVEs pode deixar de fora fraquezas críticas para auditorias, testes de segurança e revisão de componentes sensíveis.

A P3, que avalia a interação entre recorrência e severidade, mostrou que frequência e severidade devem ser tratadas como dimensões complementares. A baixa associação entre os *rankings* indica que uma dimensão não substitui a outra. O resultado mais relevante dessa etapa é a identificação do quadrante de dupla ameaça, composto por CWEs que combinam alta recorrência e alta severidade técnica. Essas fraquezas formam um subconjunto prioritário porque representam, ao mesmo tempo, problemas comuns e potencialmente danosos.

5.2. Insights para priorização prática

O trabalho fornece três contribuições práticas para equipes de desenvolvimento, segurança e auditoria. A primeira é a priorização em camadas: CWEs de dupla ameaça devem receber atenção inicial; fraquezas severas, ainda que menos frequentes, devem orientar auditorias especializadas; e fraquezas muito recorrentes, mesmo quando moderadas, devem alimentar ações de prevenção estrutural, como treinamento, revisão de código e regras de análise estática.

A segunda contribuição é mostrar que o escore composto de risco deve ser interpretado com cautela. Embora M5, o escore composto de risco, combine frequência e severidade, a concentração extrema da base faz com que o componente de volume tenha grande influência sobre o *ranking*. Esse comportamento não invalida o indicador, mas revela uma nuance metodológica importante: o escore composto é mais útil quando lido junto com M8, o quadrante de risco, que evidencia fraquezas com equilíbrio entre recorrência e impacto técnico.

A terceira contribuição é a leitura temporal e de estabilidade dos resultados. A persistência de parte das CWEs mais frequentes sugere que algumas fraquezas não são eventos isolados, mas problemas estruturais que reaparecem ao longo do tempo. Ao mesmo tempo, mudanças no *ranking* indicam que a priorização deve ser atualizada periodicamente, pois novas tecnologias, práticas de desenvolvimento e mudanças no próprio processo de classificação da NVD podem alterar o perfil das fraquezas observadas. Como os dados de vulnerabilidade são concentrados e assimétricos, a opção por testes não paramétricos reforça a leitura comparativa sem depender de pressupostos fortes de normalidade.

5.3. Relação com a literatura

Os achados dialogam com estudos que já reconhecem frequência e severidade como dimensões relevantes para priorização [Mell and Gueye 2020, Galhardo et al. 2020, Albanese et al. 2023]. A diferença deste trabalho está em combinar essas dimensões de forma simples e reproduzível, usando métricas diretamente interpretáveis por CWE: concentração acumulada, severidade média, proporção *HIGH/CRITICAL*, escore composto, correlação entre *rankings* e quadrantes de risco.

Em relação à literatura sobre concentração de vulnerabilidades, os resultados reforçam a evidência de que poucas categorias podem responder por grande parte das

ocorrências [Liu et al. 2020]. Entretanto, o estudo acrescenta uma nuance: alta frequência não implica automaticamente maior risco técnico. Por isso, a principal mensagem da análise é que a priorização deve equilibrar cobertura e impacto, evitando tanto a dependência exclusiva de contagens quanto o uso isolado do CVSS.

6. Ameaças à Validade

A validade de construto depende da qualidade dos campos da NVD. Inconsistências em classificações de CWE e em pontuações CVSS, já documentadas por [Anwar et al. 2022], podem afetar diretamente as métricas de frequência, severidade e proporção de casos graves. A auditoria de descartes realizada no pré-processamento reduz esse risco ao separar registros sem CWE válida, mas não corrige eventuais erros presentes nos registros mantidos.

A validade interna é condicionada pela mudança histórica entre CVSS v2 e CVSS v3. Como a versão 2 não possui a faixa *CRITICAL* ($\geq 9,0$), introduzida com a versão 3 a partir de 2016, comparações longitudinais de severidade podem refletir mudanças no esquema de pontuação, e não apenas mudanças reais no perfil das vulnerabilidades. As análises temporais ajudam a contextualizar esse efeito, mas não eliminam a quebra estrutural.

A validade externa é limitada pelo escopo da própria NVD. Os resultados descrevem a base global e podem não representar organizações com portfólios tecnológicos específicos, diferentes níveis de maturidade em segurança ou exposição desigual a determinados tipos de sistema. O filtro por *vendor* disponível no *pipeline* público mitiga parcialmente essa limitação, pois permite replicar a análise em recortes setoriais ou organizacionais.

Por fim, a validade de conclusão é influenciada pelo tamanho da população analisada. Testes não paramétricos são adequados à assimetria dos dados, mas, em bases grandes, podem indicar significância estatística mesmo quando o efeito é pequeno. Por isso, a interpretação dos resultados considera o tamanho do efeito, como no caso da correlação de Spearman ($\rho = -0,020$), e não apenas o *p*-valor.

7. Conclusão

Este trabalho analisou a distribuição de fraquezas de *software* na base NIST NVD entre 1999 e 2025, com o objetivo de priorizar categorias de CWE a partir da integração entre frequência histórica, severidade técnica e interação entre essas dimensões. A pesquisa adotou uma estrutura de medição baseada em GQM e respondeu a três perguntas: quais fraquezas concentram mais vulnerabilidades, quais apresentam maior severidade e como frequência e severidade se relacionam.

Os principais resultados mostram que a distribuição de vulnerabilidades entre CWEs é fortemente concentrada, com 39 categorias acumulando 80% das relações CVE–CWE; que a severidade varia de forma relevante entre fraquezas; e que frequência e severidade são praticamente independentes no agregado ($\rho = -0,020$). Também foi identificado um conjunto de 53 CWEs no quadrante de dupla ameaça, combinando alta recorrência e alta severidade técnica.

O principal insight do estudo é que priorizar apenas por volume pode gerar decisões incompletas, pois algumas fraquezas frequentes têm severidade moderada,

enquanto outras menos recorrentes apresentam maior potencial de dano. Assim, a priorização por CWE deve equilibrar cobertura, impacto técnico e interação entre dimensões. A contribuição prática está no *pipeline* reproduzível, disponível no repositório do projeto¹, que permite replicar a análise em diferentes recortes temporais ou organizacionais.

Como trabalhos futuros, recomenda-se incorporar o EPSS e o catálogo KEV para complementar a severidade técnica com evidências de exploração observada. Também são caminhos relevantes comparar o quadrante de dupla ameaça com listas como OWASP *Top 10* e CWE *Top 25*, estimar custo de remediação por fraqueza e, em etapa posterior ao escopo descritivo deste estudo, explorar modelos temporais para apoiar a gestão contínua de risco.

Referências

- Albanese, M., Iganibo, I., and Adebisi, O. (2023). A framework for designing vulnerability metrics. *Computers & Security*, 132(C):103382.
- Allodi, L., Cremonini, M., Massacci, F., et al. (2020). Measuring the accuracy of software vulnerability assessments: Experiments with students and professionals. *Empirical Software Engineering*, 25(2):1063–1094.
- Allodi, L. and Massacci, F. (2014). Comparing vulnerability severity and exploits using case-control studies. *ACM Transactions on Information and System Security*, 17(1).
- Anwar, A. et al. (2022). Cleaning the NVD: Comprehensive quality assessment, improvements, and analyses. *IEEE Transactions on Dependable and Secure Computing*.
- Basili, V. R., Caldiera, G., and Rombach, H. D. (1994). The goal question metric approach. In *Encyclopedia of Software Engineering*. Wiley.
- Galhardo, C. E. B. et al. (2020). Measurements of the most significant software security weaknesses. In *Proceedings of the Annual Computer Security Applications Conference (ACSAC)*. ACM.
- Gueye, A. et al. (2021). A decade of reoccurring software weaknesses. *IEEE Security & Privacy*, 19(6).
- Gueye, A. and Mell, P. (2021). A historical and statistical study of the software vulnerability landscape. Technical report, National Institute of Standards and Technology (NIST).
- IBM Security (2025). Cost of a data breach report 2025. Technical report, IBM Corporation.
- Jacobs, J. et al. (2021). Exploit prediction scoring system (EPSS). *Digital Threats: Research and Practice*, 2(3).
- Liu, Y. et al. (2020). A large-scale empirical study on vulnerability distribution within projects and the lessons learned. In *Proceedings of the 42nd International Conference on Software Engineering (ICSE)*. ACM.

¹<https://github.com/ICEI-PUC-Minas-PPLES-TI/plf-es-2026-1-ti6-8508100-ti6grupo2/tree/master>

- Mell, P. and Gueye, A. (2020). A suite of metrics for calculating the most significant security relevant software flaw types. In *Proceedings of the IEEE 44th Annual Computers, Software, and Applications Conference (COMPSAC)*. IEEE.
- Ponte, F. et al. (2023). CVEjoin: An information security vulnerability and threat intelligence dataset. In *Proceedings of the 17th International Conference on Advanced Information Networking and Applications (AINA)*. Springer.
- Sharma, M. et al. (2023). A hybrid scoring system for prioritization of software vulnerabilities (VIEWSS). *Computers & Security*.
- Williams, R. et al. (2018). Analyzing evolving trends of vulnerabilities in national vulnerability database. In *Proceedings of the IEEE International Conference on Big Data (BigData)*. IEEE.

Apêndices metodológicos e evidências complementares

A. Dicionário de métricas CWE e reprodutibilidade

A.1. Métricas e indicadores analisados

Os apêndices possuem caráter complementar e concentram detalhes técnicos extensos que apoiam a leitura do corpo principal. Este apêndice apresenta, de forma sintética, as métricas centrais (M1–M8) e os indicadores suplementares (M9–M11) do *pipeline* GQM, com suas respectivas formas de cálculo. As Tabelas 2, 3 e 4 detalham, respectivamente, as métricas de frequência, severidade técnica e interação entre frequência e severidade, enquanto a Tabela 5 apresenta os indicadores de concentração, persistência temporal e sobreposição entre *rankings*.

Tabela 2. Métricas da Pergunta 1: frequência

Métrica	Descrição	Forma de cálculo
M1	Frequência absoluta de CVEs por CWE	$M1(c) = \{cve_id : (cve_id, c) \in B\} $
M2	Percentual acumulado de Pareto	$M2(i) = \frac{\sum_{k=1}^i cves_count(k)}{\sum_{k=1}^N cves_count(k)} \times 100$
M7	Tendência temporal por <i>Compound Annual Growth Rate</i> (CAGR)	$M7(c) = \left(\frac{count_{c,t_{fim}}}{count_{c,t_{ini}}} \right)^{\frac{1}{t_{fim}-t_{ini}}} - 1$

Fonte: Elaborado pelos autores.

Tabela 3. Métricas da Pergunta 2: severidade e impacto

Métrica	Descrição	Forma de cálculo
M3	CVSS médio por CWE	$M3(c) = \frac{1}{n_c} \sum_{i \in CVEs(c)} cvss_score_i$
M4	Proporção de casos <i>HIGH/CRITICAL</i> por CWE	$M4(c) = \frac{ \{i \in CVEs(c) : sev_i \in \{HIGH, CRITICAL\}\} }{ CVEs(c) } \times 100$

Fonte: Elaborado pelos autores.

Tabela 4. Métricas da Pergunta 3: interação entre frequência e severidade

Métrica	Descrição	Forma de cálculo
M5	Escore de risco composto	$M5(c) = \frac{cves_count(c)}{\max_k cves_count(k)} \times \frac{cvss_medio(c)}{10}$
M6	Correlação de Spearman entre <i>rankings</i> de frequência e severidade	$M6 = \rho_s(rank_freq, rank_severity)$
M8	Quadrante de risco (dupla ameaça)	$Q3_{freq} = P_{75}(cves_count),$ $Q3_{cvss} = P_{75}(cvss_medio);$ dupla ameaça se $cves_count(c) \geq Q3_{freq}$ e $cvss_medio(c) \geq Q3_{cvss}$

Fonte: Elaborado pelos autores.

Tabela 5. Indicadores suplementares

Indicador	Descrição	Forma de cálculo
M9	Índice de Gini sobre frequência	$G = \frac{2 \sum_{i=1}^n i \cdot x_{(i)} - (n+1) \sum_i x_{(i)}}{n \sum_i x_{(i)}}$
M10	Persistência do <i>top-20</i> entre anos	$M10(t) = J(Top20_{t-1}, Top20_t)$
M11	Sobreposição entre <i>top-10</i> de M1, M3 e M5	$M11 = J(A, B) = \frac{ A \cap B }{ A \cup B }$, calculado para cada par de <i>rankings</i>

Fonte: Elaborado pelos autores.

A.2. Processo de coleta, filtros e pré-processamento dos dados

A coleta principal utilizou a API NVD v2.0, no *endpoint* `https://services.nvd.nist.gov/rest/json/cves/2.0`, cobrindo o período de 1999 a 2025 sem filtro de *vendor*. A execução usada nos resultados foi registrada em 27/05/2026 21:21:22, conforme o arquivo de metadados da coleta. O intervalo foi particionado em janelas mensais, com filtros *pubStartDate* no formato `YYYY-MM-DDT00:00:00.000` e *pubEndDate* no formato `YYYY-MM-DDT23:59:59.999`. A paginação empregou *resultsPerPage=2000* e *startIndex* incremental até *totalResults*; antes da paginação completa de cada janela, o total de registros foi consultado com *resultsPerPage=1* e *startIndex=0*.

Para controle de taxa e robustez, o coletor adotou intervalo mínimo de 0,65 s entre requisições com chave de API e 6,1 s sem chave, *timeout* de 60 s e até sete tentativas por requisição. Em respostas HTTP 429, o procedimento respeitou o cabeçalho *Retry-After*; em respostas 503/504 e falhas transitórias de rede, utilizou recuo exponencial com variação aleatória, limitado a 300 s. A execução também gerou *checkpoints* mensais em `data/checkpoints/YYYY-MM.parquet` e *cache* de totais em `data/checkpoints/_totals.parquet`, permitindo retomada da coleta e auditoria dos totais por janela.

No pré-processamento, foram mantidas apenas classificações de fraqueza no formato `CWE-<número>`; rótulos genéricos, como `NVD-CWE-Other` e `NVD-CWE-noinfo`, foram descartados das análises por CWE. O ambiente computacional utilizou *Python* 3.10+, *pyarrow* $\geq 14.0.0$ e *SciPy* $\geq 1.10.0$; as demais dependências,

incluindo *requests*, *polars*, *matplotlib*, *seaborn* e *scikit-posthocs*, são especificadas no arquivo de requisitos do repositório público.

B. Evidências complementares por pergunta de pesquisa

Este apêndice reúne evidências adicionais e complementares que sustentam os resultados da Seção 4. Os elementos estão organizados na mesma ordem das subseções do corpo principal: contexto da base, frequência e concentração de vulnerabilidades por CWE (P1), severidade técnica por fraqueza (P2) e interação entre frequência e severidade (P3). A Figura 6 e a Figura 7 sintetizam a caracterização inicial da base analisada.

B.1. Caracterização da base NVD analisada

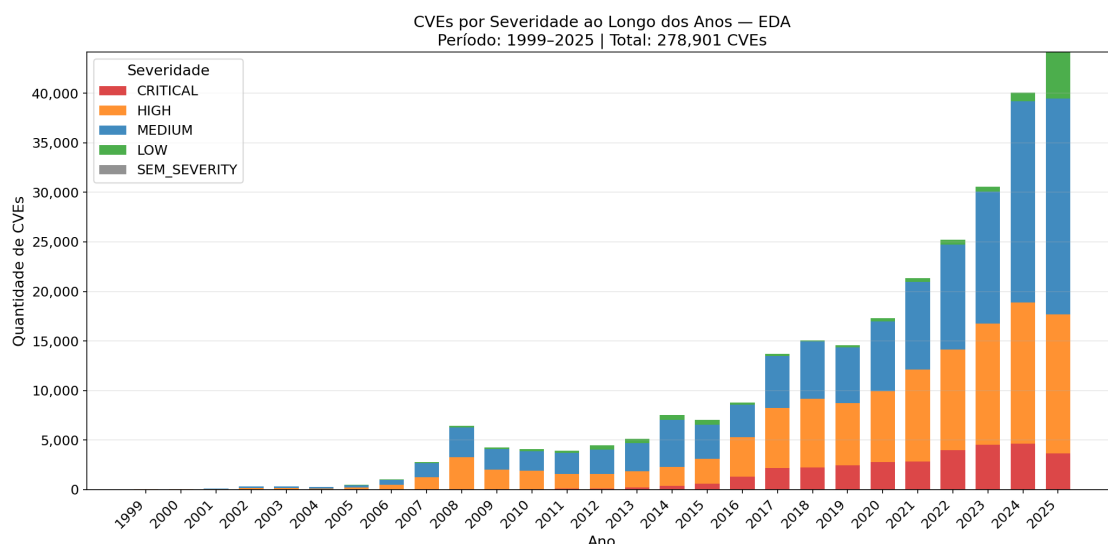


Figura 6. Volume absoluto de CVEs por faixa de severidade ao longo dos anos (1999–2025).

A Tabela 6 sintetiza as estatísticas descritivas globais da base. Esses indicadores delimitam o tamanho da população analisada e contextualizam a cobertura das métricas calculadas.

A Tabela 7 apresenta a distribuição de CVEs por faixa de severidade. Essa distribuição complementa a Figura 7 ao agrupar os escores em categorias interpretáveis.

B.2. Evidências de P1: frequência e concentração por CWE

A Figura 8 mostra a desigualdade da distribuição de CVEs por CWE por meio da curva de Lorenz. As Figuras 9 e 10 complementam essa leitura ao destacar a evolução temporal das fraquezas mais frequentes.

A Tabela 8 apresenta os limiares de concentração acumulada.

A Tabela 9 apresenta a persistência do *top-20* de frequência entre anos consecutivos, medida pelo índice de Jaccard (M10). O indicador evidencia a estabilidade relativa das fraquezas mais recorrentes ao longo da série histórica.

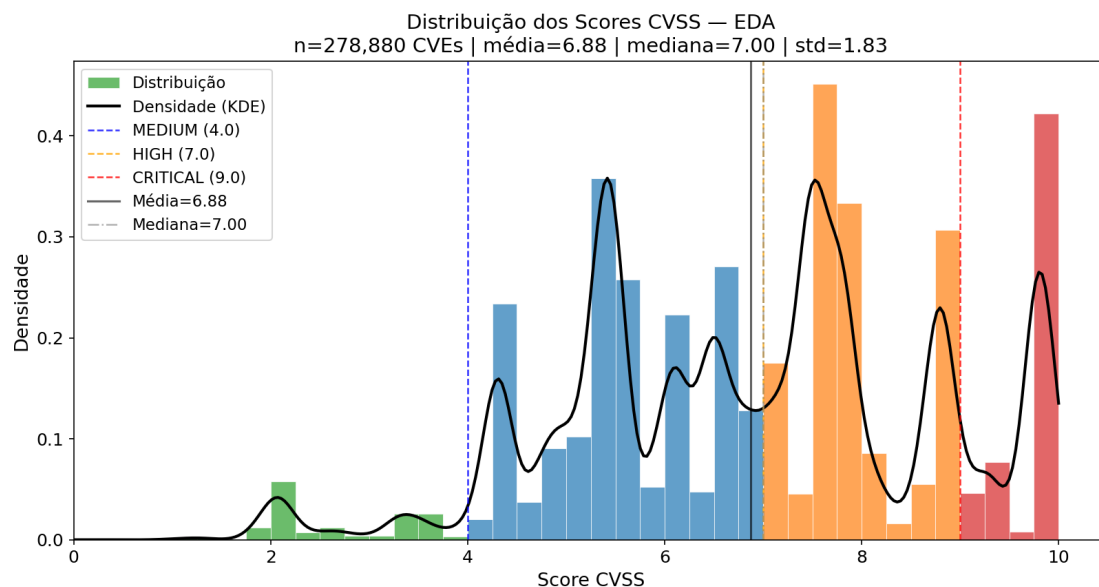


Figura 7. Distribuição global dos *scores* CVSS na base analisada ($n = 278.880$; média 6,88; mediana 7,00; distribuição multimodal com picos em 5,5, 7,5 e 9,8).

B.3. Evidências de P2: severidade técnica por CWE

A Figura 11 compara CVSS médio e proporção de casos *HIGH/CRITICAL* entre as CWEs mais severas. A Figura 12 complementa essa análise ao mostrar a composição anual das faixas de severidade.

A Tabela 10 apresenta as dez CWEs com maior CVSS médio entre aquelas com pelo menos 30 CVEs associados. O filtro mínimo reduz distorções causadas por categorias com poucas observações.

B.4. Evidências de P3: interação entre frequência e severidade

A Figura 13 apresenta o *score* de risco composto por CWE, enquanto a Figura 14 mostra a sobreposição entre critérios de priorização. Em conjunto, esses elementos detalham a

Tabela 6. Estatísticas descritivas globais da base NVD (1999–2025)

Indicador	Valor
Total de CVEs no período (NVD)	324.593
Registros descartados	70.791
CVEs distintos	253.802
Relações CVE–CWE	278.912
CWEs distintas	749
Cobertura CVSS	99,99%
CVSS médio (mediana)	6,88 (7,00)
Desvio padrão do CVSS	1,83
<i>Interquartile Range</i> (IQR) do CVSS (Q1–Q3)	5,50–8,10

Fonte: Elaborado pelos autores a partir da base NIST NVD.

Tabela 7. Distribuição de CVEs por faixa de severidade

Faixa	CVEs	%	CVSS médio
<i>CRITICAL</i>	32.057	11,49	9,72
<i>HIGH</i>	108.894	39,04	7,98
<i>MEDIUM</i>	127.021	45,54	5,58
<i>LOW</i>	10.897	3,91	2,62
<i>NONE</i>	11	0,00	0,00

Fonte: Elaborado pelos autores a partir da base NIST NVD.

Tabela 8. Concentração acumulada: CWEs necessárias por limiar de cobertura

Limiar de cobertura	CWEs necessárias
25% das CVEs	3
50% das CVEs	11
75% das CVEs	30
80% das CVEs	39
90% das CVEs	76
Índice de Gini	0,922
Índice Herfindahl-Hirschman (HHI)	0,041

Fonte: Elaborado pelos autores.

baixa concordância entre frequência, severidade e risco composto.

A Tabela 11 sintetiza os indicadores de concordância entre dimensões (M6, M11) e a distribuição por quadrante (M8). A tabela resume os resultados complementares usados para interpretar a independência entre frequência e severidade.

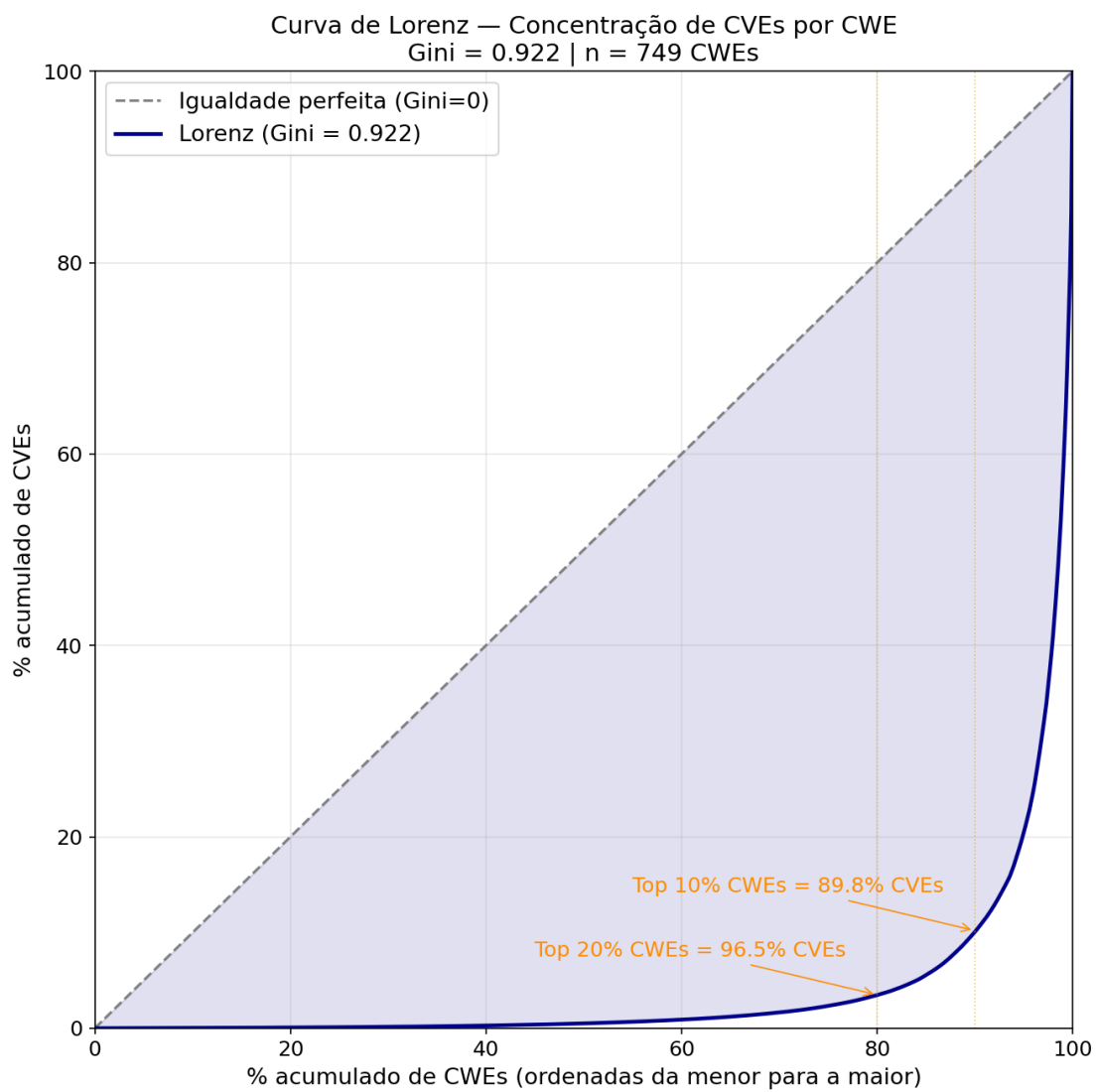


Figura 8. Curva de Lorenz e índice de Gini sobre a distribuição de CVEs por CWE
($G = 0,922$).

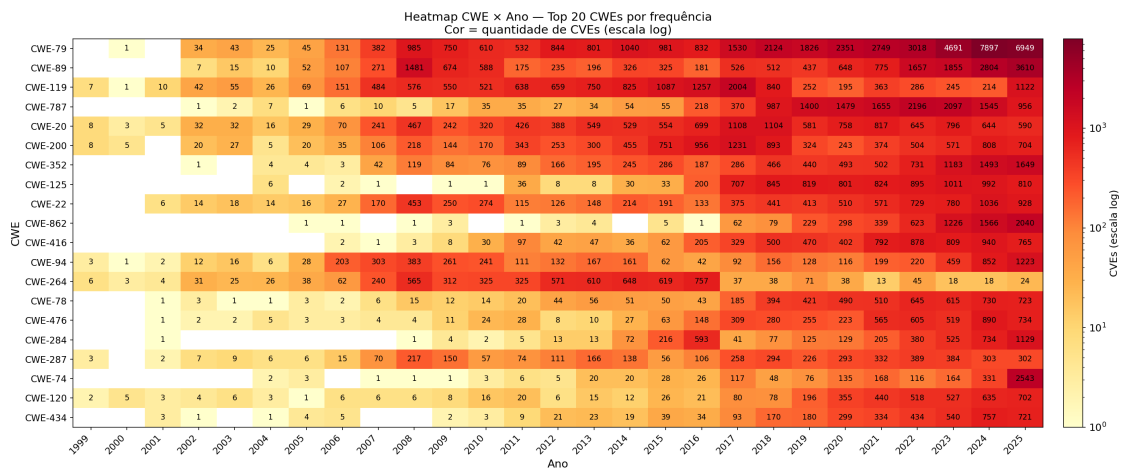


Figura 9. Heatmap CWE × Ano para as 20 CWEs mais frequentes (escala logarítmica).

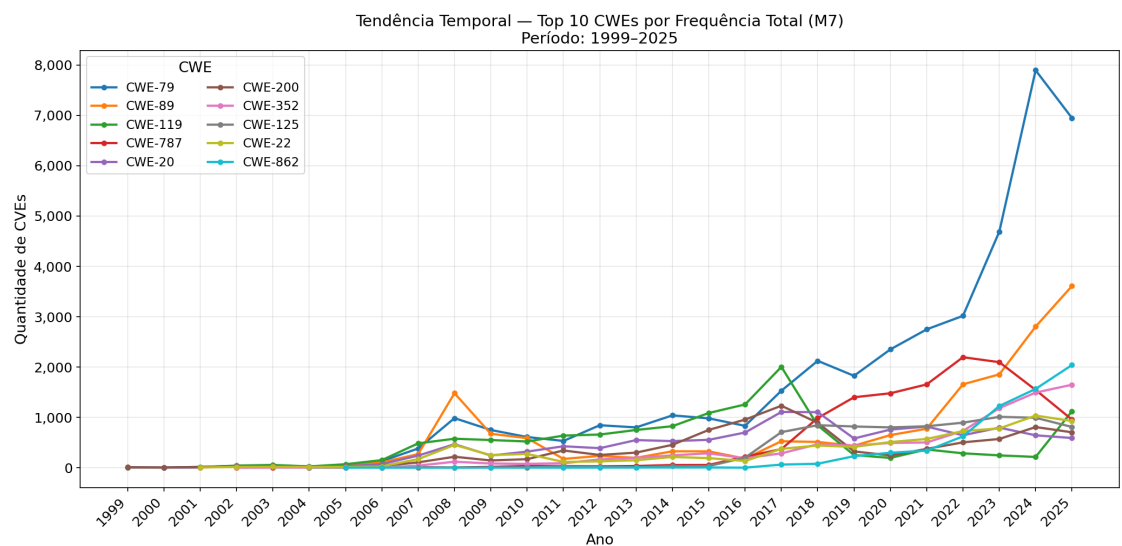


Figura 10. Tendência temporal das 10 CWEs mais frequentes — evolução anual com eixos independentes (M7).

Tabela 9. Persistência do *top-20* de frequência entre anos consecutivos (M10), 1999–2025

Transição	Jaccard	Entrantes	Saídas
1999→2000 ^a	0,370	8	9
2000→2001 ^a	0,267	12	10
2001→2002	0,333	10	10
2002→2003	0,739	3	3
2003→2004	0,600	5	5
2004→2005	0,481	7	7
2005→2006	0,538	6	6
2006→2007	0,739	3	3
2007→2008	0,905	1	1
2008→2009	0,818	2	2
2009→2010	0,818	2	2
2010→2011	0,818	2	2
2011→2012	0,818	2	2
2012→2013	0,818	2	2
2013→2014	0,818	2	2
2014→2015	0,739	3	3
2015→2016	0,600	5	5
2016→2017	0,600	5	5
2017→2018	0,600	5	5
2018→2019	0,739	3	3
2019→2020	0,667	4	4
2020→2021	0,667	4	4
2021→2022	0,818	2	2
2022→2023	0,818	2	2
2023→2024	0,667	4	4
2024→2025	0,818	2	2
Jaccard médio (1999–2025): 0,678			

^a Em 1999 (19 CWEs) e 2000 (18 CWEs) o *top-20* equivale a todas as CWEs do ano; essas transições são menos informativas.

Fonte: Elaborado pelos autores.

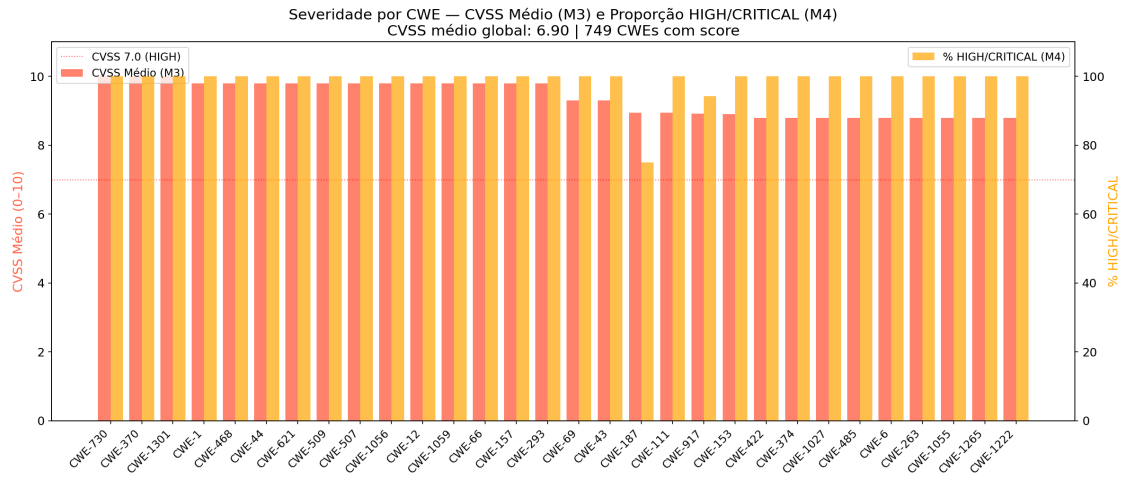


Figura 11. CVSS médio (M3) e proporção *HIGH/CRITICAL* (M4) para as 30 CWEs mais severas.

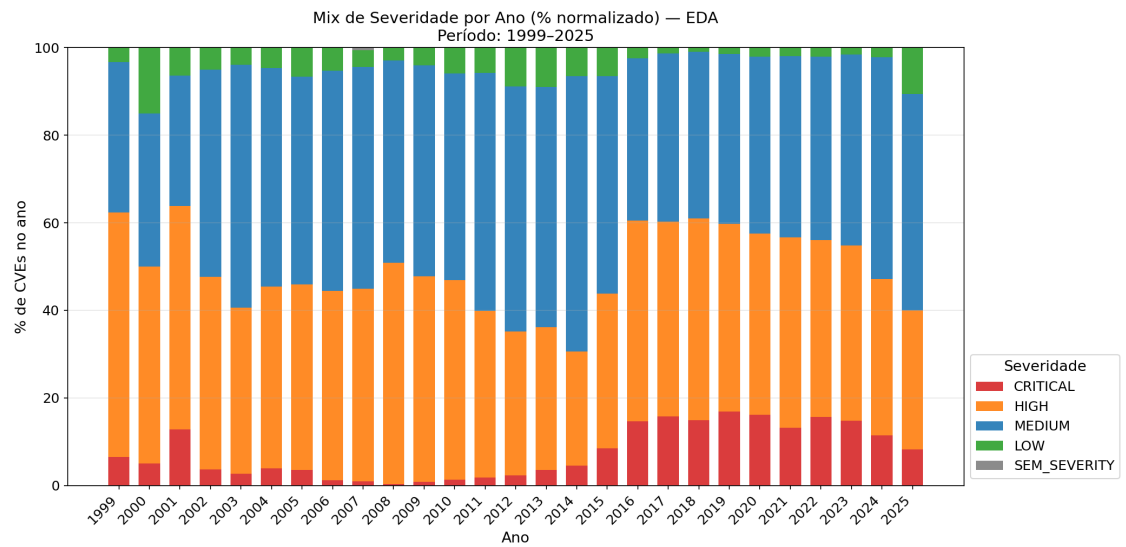


Figura 12. Mix de severidade por ano — percentual normalizado (1999–2025). Mudança estrutural em 2016 com introdução da faixa *CRITICAL* pelo CVSS v3.

Tabela 10. Top-10 CWEs por CVSS médio (M3), filtradas por $n \geq 30$

#	CWE	CVEs	CVSS médio	%H+C
1	CWE-917 (<i>Expression Language Injection</i>)	173	8,92	94,2
2	CWE-502 (<i>Deserialization</i>)	2.280	8,55	90,1
3	CWE-1321 (<i>Prototype Pollution</i>)	423	8,45	81,8
4	CWE-288 (<i>Auth. Bypass Using Alt. Path</i>)	421	8,44	82,2
5	CWE-95 (<i>Eval Injection</i>)	98	8,43	88,8
6	CWE-78 (<i>OS Command Injection</i>)	5.033	8,42	87,8
7	CWE-798 (<i>Hard-coded Credentials</i>)	1.570	8,38	82,6
8	CWE-680 (<i>Integer Overflow to Buffer</i>)	101	8,23	90,1
9	CWE-470 (<i>Unsafe Reflection</i>)	44	8,17	81,8
10	CWE-434 (<i>Unrestricted File Upload</i>)	3.692	8,15	80,9

Fonte: Elaborado pelos autores.

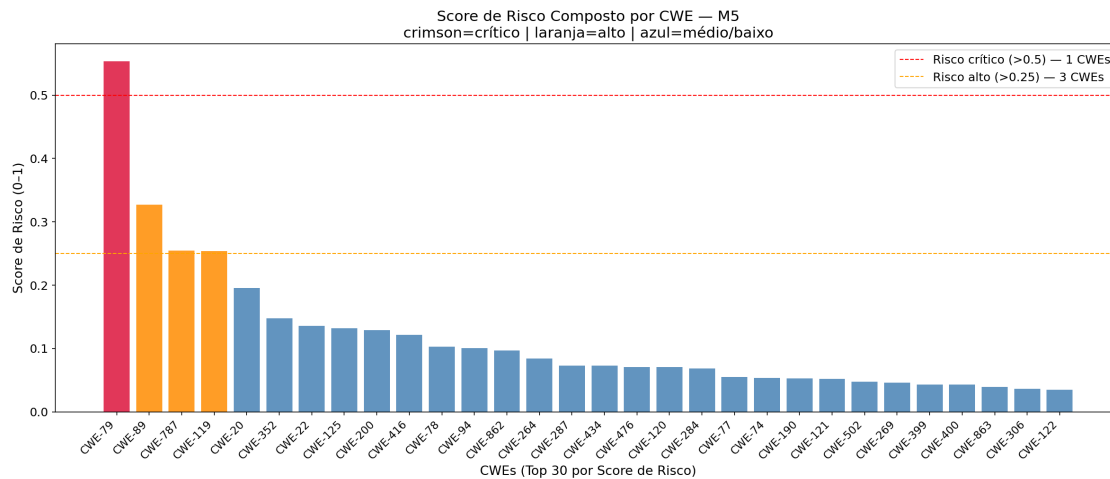


Figura 13. Score de risco composto por CWE (M5) — top-30 por score.

Tabela 11. Indicadores de concordância e quadrantes de risco

Indicador	Valor
CWEs válidas (n)	749
Spearman ρ (freq $\times$ CVSS)	-0,020 ($p = 0,59$)
Pearson r (log freq $\times$ CVSS)	0,006 ($p = 0,86$)
Jaccard top-20 freq $\times$ sev	0,000
Q3 frequência	66 CVEs
Q3 CVSS médio	7,52
Quadrante Dupla Ameaça	53 CWEs (7%)
Quadrante Frequente	137 CWEs (18%)
Quadrante Severa	135 CWEs (18%)
Quadrante Baixo Risco	424 CWEs (57%)

Fonte: Elaborado pelos autores.

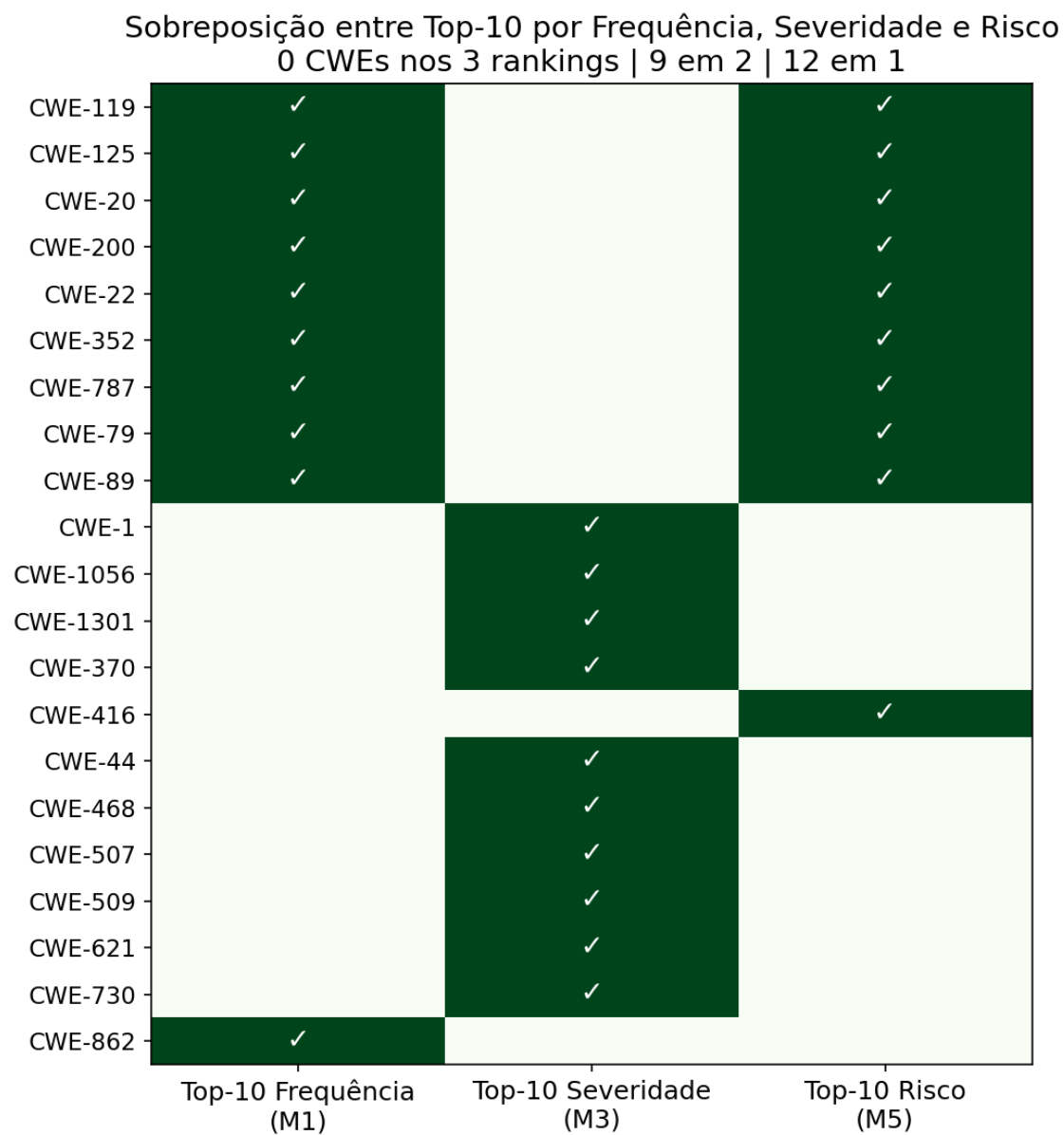


Figura 14. Sobreposição entre *top-10* por frequência, severidade e risco composto (M11). Jaccard freq $\times$ sev = 0,000.